

NES555 — Lab 4: Vulnerability Scanning & Web Application Penetration Testing

Course: NES555 — Ethical Hacking Lab

Version: 2025-10-21

Lab environment: Kali Linux VM, pfSense Firewall VM, OWASP Broken Web Application (OWASP BWA) VM

Lab Overview — Background and Purpose

Modern enterprise applications rely heavily on **web-based interfaces**, exposing them to web-specific vulnerabilities such as SQL injection, XSS, weak authentication, and insecure configurations.

This lab introduces students to **vulnerability scanning** and **web application assessment** using industry-recognized open-source tools.

You will use:

- **OpenVAS (Greenbone Vulnerability Management)** for network-level vulnerability scanning.
 - **Nikto** for web server vulnerability scanning.
 - **Burp Suite** for web proxy interception and site mapping.
 - **Hydra** for brute-forcing web login forms (ethical demonstration only).
-

Learning Objectives

By the end of this lab, students will be able to:

1. Configure and execute a vulnerability scan using **OpenVAS**.
 2. Identify and interpret vulnerabilities discovered on a target system.
 3. Perform web application scanning using **Nikto**.
 4. Set up and configure **Burp Suite** for intercepting and analyzing HTTP traffic.
 5. Build a **site map** and understand how Burp categorizes requests and responses.
 6. Conduct a controlled **web brute-force attack** on a test application.
-

Estimated Time

120 minutes (2 hours)

Lab Environment

Virtual Machine	IP Address	Username	Password	Notes
Kali Linux	192.168.68.254	root	toor	Attacker machine
pfSense	192.168.68.1	admin	pfsense	Firewall/router
OWASP Broken Web App (BWA)	192.168.68.12	root	(none)	Target vulnerable web server

Important: Do not scan or attack any system outside the assigned lab network.

Deliverables

Submit a single PDF named
NES555_Lab4_<YourName>_<ID>.pdf
including:

- Executive summary (2–3 lines).
 - Key OpenVAS, Nikto, and Burp Suite screenshots.
 - A concise table of discovered vulnerabilities and suggested mitigations.
 - A short reflection (lessons learned and ethical considerations).
-

Tools Quick Reference

Tool	Description
OpenVAS (Greenbone)	Comprehensive vulnerability scanner
Nikto	Web server and CGI vulnerability scanner
Burp Suite Community	Web proxy/intercept and analysis suite
Hydra	Password/brute-force testing framework
Firefox ESR	Web browser for proxy and target access

Tasks — Step-by-Step Guide

Task 1 — Network Vulnerability Scanning with OpenVAS (25–30 min)

Background:

Before performing web-specific testing, a full network vulnerability scan helps identify misconfigurations, open ports, and unpatched services.

Commands:

```
sudo gvm-setup
sudo gvm-start
```

Wait until setup completes, then open the Greenbone web interface:

- URL: `https://127.0.0.1:9392`
- Login: `admin`
- Password: (shown during setup)

Steps:

1. Navigate to **Configuration** → **Targets** → **New Target**
 - Name: `OWASP-BWA`
 - Hosts: `192.168.68.12`
2. Create a new scan under **Scans** → **Tasks** → **New Task**
 - Name: `Lab4 Vulnerability Scan`
 - Target: `OWASP-BWA`
 - Scan Config: *Full and Fast*
3. Start the scan and wait for completion.
4. Open **Reports** → **Results** and review the findings.

Expected Findings:

- Unpatched Apache version
- Outdated PHP configuration
- Directory indexing enabled
- Missing security headers

Optional (Export):

```
# Export scan results
sudo gvm-cli --xml "<get_reports report_id='YOUR_REPORT_ID' format_id='pdf'>"
```

Task 2 — Web Server Scanning with Nikto (20–25 min)**Background:**

Nikto performs in-depth testing of web servers to identify outdated versions, misconfigurations, and known vulnerabilities.

Commands:

```
# Verify Nikto help and options
nikto -Help

# Basic scan
nikto -host 192.168.68.12

# Check available plugins
nikto -list-plugins

# Use specific plugin to check outdated software
nikto -Plugins outdated -host 192.168.68.12

# Check HTTP methods
nikto -Plugins httpoptions -host 192.168.68.12

# Run standard tests
nikto -Plugins tests -host 192.168.68.12

# Generate HTML report
nikto -host 192.168.68.12 -output ~/nes555/lab4/nikto_report.html
```

Steps:

1. Analyze the report file:
 - o Open **Files** → **Open Folder** → **nikto_report.html**
 - o Right-click → **Open With** → **Firefox ESR**
2. Review vulnerabilities:
 - o OSVDB IDs
 - o Supported HTTP methods
 - o Directory listings
 - o Server banner info

Expected Results:

- Apache version exposure
 - Cross-site tracing allowed
 - HTTP TRACE/OPTIONS enabled
 - Possible XSS or directory traversal indicators
-

Task 3 — Setting up Burp Suite (20–25 min)

Background:

Burp Suite intercepts and manipulates HTTP/S traffic between browser and server, enabling web application analysis.

Steps:

1. Launch Burp Suite:

2. burpsuite
 3. In Java popup → click **OK**.
 4. Accept the license → **I Accept**.
 5. Choose **Temporary Project** → **Next** → **Use Burp Defaults** → **Start Burp**.
 6. When prompted that Burp is out-of-date → **OK** (ignore).
 7. Launch Firefox:
 8. firefox &
 9. Configure proxy in Firefox:
 - Go to **Menu** → **Settings** → **Network Settings** → **Manual proxy configuration**
 - HTTP Proxy: 127.0.0.1
 - Port: 8080
 - Check **Use this proxy server for all protocols**
 - Click **OK**
 10. In Burp, open the **Proxy tab** → **Intercept is on** → click to **turn off** interception for now.
-

Task 4 — Building a Site Map with Burp Suite (15–20 min)

Background:

Burp's **Target tab** records all HTTP/S requests passing through the proxy and organizes them into a site map.

Steps:

1. In Firefox, browse to the target:
2. `http://192.168.68.12`
3. Switch back to Burp Suite → **Target tab**.
4. You will see requests to `http://192.168.68.12` in the left pane.
5. Right-click on the host → **Add to scope**.
6. When prompted, click **Yes** to limit analysis to this target.
7. Go to **Target** → **Scope tab** and verify inclusion.
8. Under **Proxy** → **Options** → **Intercept Client Requests**, check:
 - “And URL is in target scope” to capture only relevant requests.

Expected Result:

- Burp displays a structured site map of the OWASP BWA application.
 - URLs grouped by folders, parameters, and file types.
 - Useful for identifying login pages and input fields for testing.
-

Task 5 — Brute Forcing a Web Application (15–20 min)

Background:

This section demonstrates a **controlled brute-force attack** using **Hydra** to test weak web login

forms.

Only perform this on **OWASP BWA** or instructor-provided targets.

Steps:

1. Identify a login form, e.g., `http://192.168.68.12/dvwa/login.php`.
2. Use Hydra with the following syntax:
3. `hydra -L /usr/share/wordlists/common_usernames.txt \`
4. `-P /usr/share/wordlists/rockyou.txt \`
5. `192.168.68.12 http-post-form \`
6. `"/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login`
`failed" \`
7. `-V -t 4`
8. Observe valid credentials when Hydra reports `[80][http-post-form] host: ...`
`login: ... password: ....`

Expected Notes:

- Valid username/password combinations found.
- Demonstrates importance of strong authentication mechanisms.

Task 6 — Correlation & Reporting (15–20 min)

Combine Findings:

Source	Tool	Finding	Severity	Suggested Mitigation
Network	OpenVAS	Outdated Apache 2.2.8	High	Update to latest version
Web	Nikto	TRACE/OPTIONS enabled	Medium	Disable unsafe HTTP methods
Web	Burp Suite	XSS parameter reflected	Medium	Input validation
Auth	Hydra	Weak “admin:admin” credentials	High	Enforce complex passwords

Final Step:

- Summarize your observations and remediation steps.
- Reflect on the ethical implications of automated scanning.

Troubleshooting & Notes

- If OpenVAS doesn't start, run:
- `sudo gvm-check-setup`
- `sudo gvm-feed-update`

- If Burp doesn't intercept, verify Firefox proxy settings (127.0.0.1:8080).
 - Use **Firefox ESR**, not Chromium, to view Nikto reports.
 - Ensure OWASP BWA VM is running and reachable (ping or `curl http://192.168.68.12`).
-

Submission Checklist

✓ NES555_Lab4_<YourName>_<ID>.pdf including:

- Executive summary
 - Screenshots of OpenVAS, Nikto, Burp Suite
 - Findings table
 - Reflections on vulnerabilities and mitigations
-

Wrap-up Questions

1. What are the main differences between OpenVAS and Nikto in terms of scan depth and focus?
 2. How does Burp Suite's proxy capability enhance manual testing beyond automated scanners?
 3. What steps can an organization take to defend against brute-force web login attacks?
-

Would you like me to produce a **student handout version (1-page quick guide)** or an **instructor answer key version (with sample screenshots and expected results)** next?